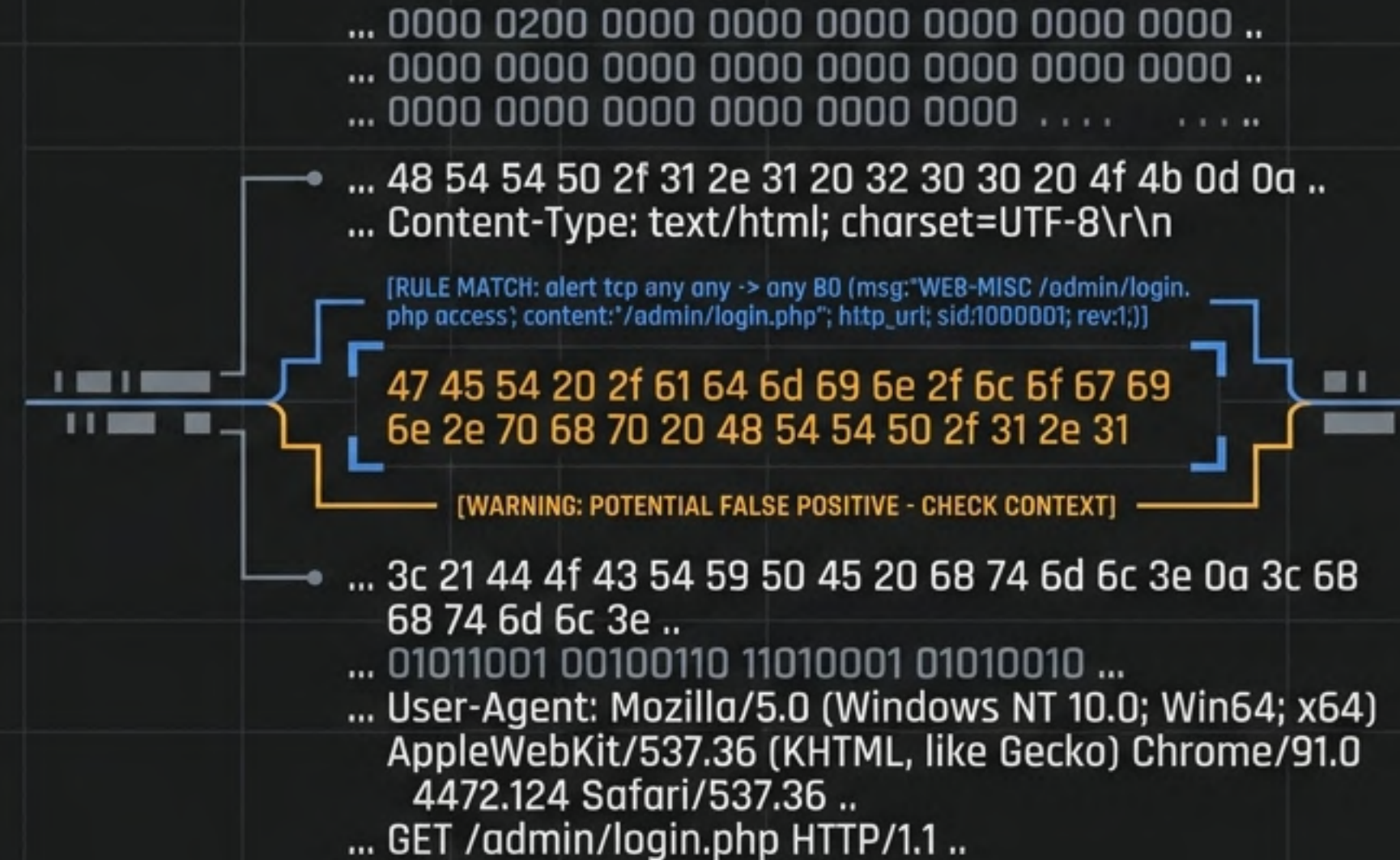


Lección 05

IDS y Afinamiento de Reglas con Snort 3

Material de estudio preparatorio. Conceptos, anatomía de reglas y validación de tráfico para análisis de red.



The diagram illustrates a network traffic capture with a central packet highlighted. The packet's payload is shown in hexadecimal and ASCII. A rule match is indicated by a blue bracket, and a warning is shown by an orange bracket. The traffic is represented by a central line with sidebars containing vertical bars of varying heights, suggesting a packet capture or network flow visualization.

```
... 0000 0200 0000 0000 0000 0000 0000 0000 ..  
... 0000 0000 0000 0000 0000 0000 0000 0000 ..  
... 0000 0000 0000 0000 0000 0000 . . . . .  
  
... 48 54 54 50 2f 31 2e 31 20 32 30 30 20 4f 4b 0d 0a ..  
... Content-Type: text/html; charset=UTF-8\r\n  
[RULE MATCH: alert tcp any any -> any 80 (msg:"WEB-MISC /admin/login.  
php access; content:'/admin/login.php'; http_url; sid:1000001; rev:1;)]  
  
47 45 54 20 2f 61 64 6d 69 6e 2f 6c 6f 67 69  
6e 2e 70 68 70 20 48 54 54 50 2f 31 2e 31  
  
[WARNING: POTENTIAL FALSE POSITIVE - CHECK CONTEXT]  
  
... 3c 21 44 4f 43 54 59 50 45 20 68 74 6d 6c 3e 0a 3c 68  
68 74 6d 6c 3e ..  
... 01011001 00100110 11010001 01010010 ...  
... User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)  
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/91.0  
4472.124 Safari/537.36 ..  
... GET /admin/login.php HTTP/1.1 ..
```

El Ecosistema de Seguridad



Firewall (Control Preventivo)

Toma decisiones. Su trabajo es permitir o denegar el tráfico basándose en políticas de acceso estáticas.

Sensor IDS (Control Detectivo)

Observa pasivamente. Recibe una copia del tráfico, lo analiza contra sus firmas y genera alertas. No bloquea por sí mismo.

El Principio de Visibilidad

Un sensor IDS ubicado detrás del firewall solamente puede analizar el tráfico que el firewall dejó pasar. Lo denegado en el perímetro nunca llega al IDS.

¿Observar o Actuar? IDS vs. IPS

Intrusion Detection System (IDS)

- Modo: Pasivo, fuera de línea.
- Acción:
 - Detecta y genera alertas.
 - Riesgo sobre el flujo: Bajo. Al operar de forma pasiva y fuera de línea, una falla del IDS normalmente no interrumpe el tráfico.
- Ejemplo:
 - Sensor conectado mediante SPAN/TAP.

Intrusion Prevention System (IPS)

- Modo: En línea: el tráfico atraviesa el dispositivo.
- Acción:
 - Detecta, alerta y puede bloquear tráfico.
 - Riesgo sobre el flujo: Mayor. Una decisión incorrecta o una falla puede afectar tráfico legítimo porque el IPS está en línea.
- Ejemplo:
 - Función IPS habilitada en un firewall o NGFW.

Similitud clave: Ambos pueden utilizar detección basada en reglas o firmas para identificar patrones conocidos en el tráfico.

El Laboratorio: ¿Por qué analizar en diferido?

Snort 3 es un motor de análisis de red que puede operar en tiempo real o analizar el pasado.

Análisis en vivo (-i)



Escucha una interfaz de red (ej. eth0).
El tráfico ocurre una vez y desaparece.
(No usado en esta actividad).

Análisis offline (-r)

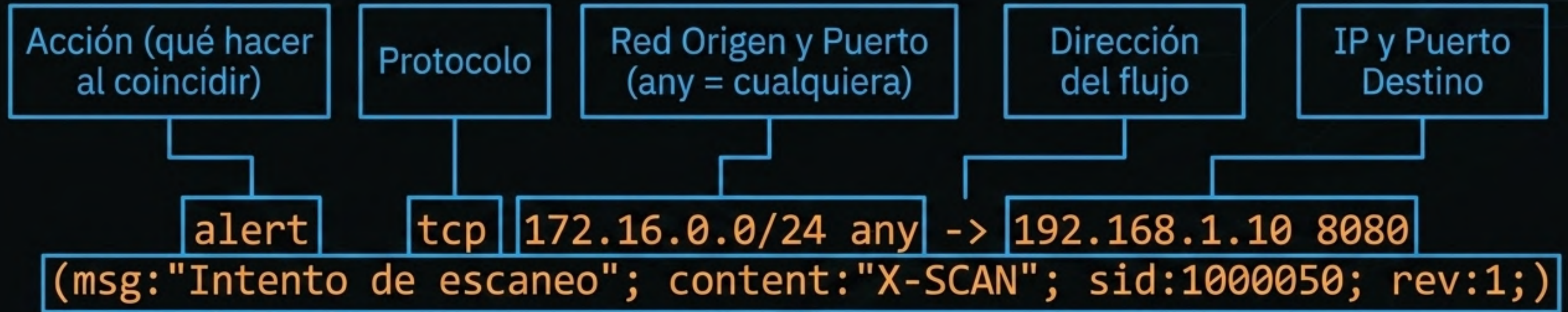


Lee un archivo de captura de paquetes (PCAP).
¿Por qué usar -r captura.pcap?

- ✓ **Aislamiento:** Permite trabajar en un entorno seguro y sin red.
- ✓ **Repetitividad:** El mismo tráfico puede ser analizado 100 veces mientras afinas la regla hasta alcanzar la perfección.

Anatomía de una Regla Snort

El Encabezado (¿Quién, Cómo y Hacia Dónde?)

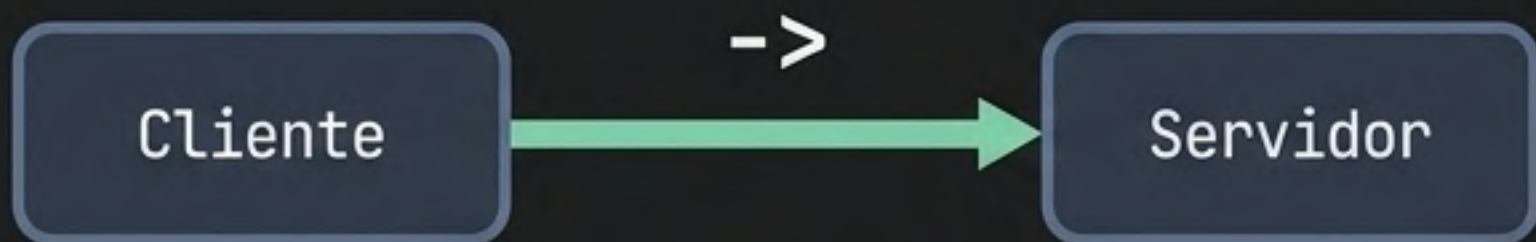


El Cuerpo (¿Qué estamos buscando?)

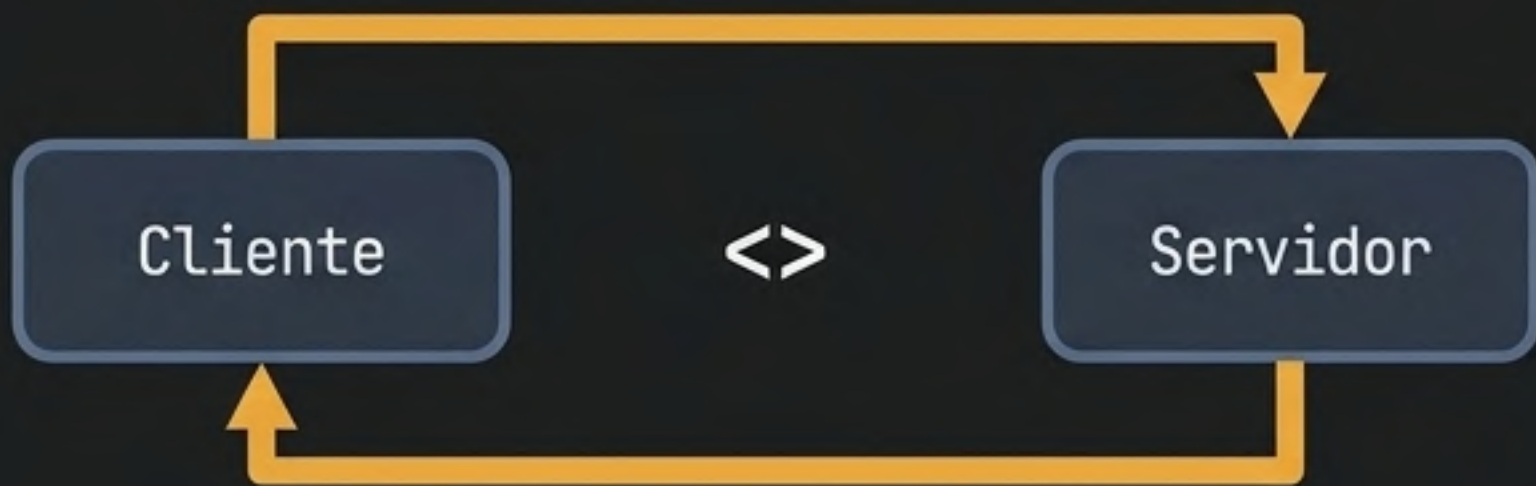
Contiene las opciones separadas por ;.
Define el mensaje, el patrón exacto a buscar en los datos y los metadatos.

El Sentido del Tráfico: -> vs <>

El operador de dirección es vital para evitar ruido en los registros.



Unidireccional (->): Analiza exclusivamente paquetes que viajan desde la IP origen hacia la IP destino (Ej: un cliente haciendo una petición web).



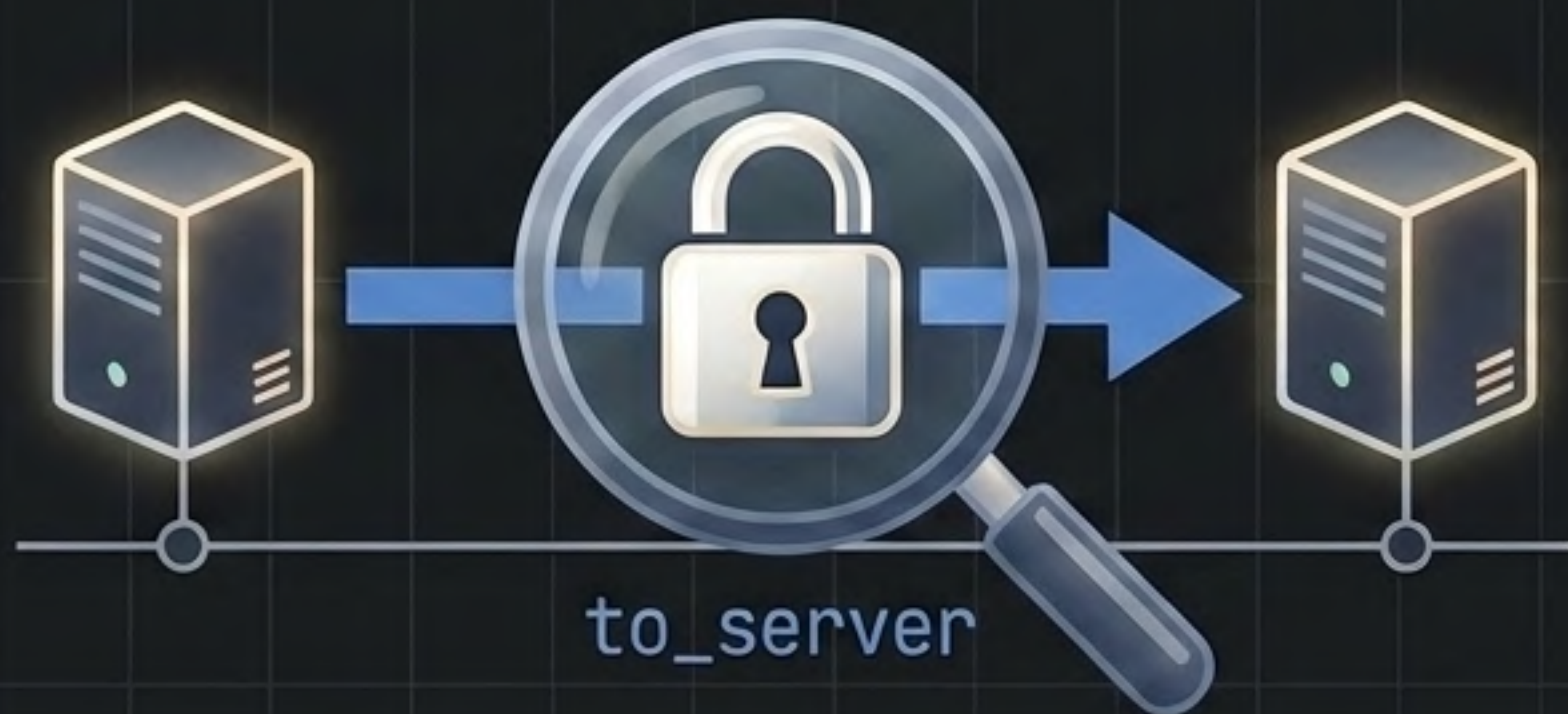
Bidireccional (<>): Considera a ambos lados como origen o destino indistintamente. Analiza petición del cliente y respuesta del servidor.



¡Cuidado! Usar <> combinado con una IP amplia como 'any' multiplicará las alertas no deseadas. Snort detectará la palabra clave sin importar quién la envíe o reciba.

Entendiendo el Estado: flow

No todo el tráfico es relevante. A veces solo queremos analizar conexiones que ya establecieron comunicación real.



```
flow:to_server,established;
```

- **established:** Solo coincide con tráfico que Snort considera parte de una conexión TCP establecida.
- **to_server:** Revisa únicamente los paquetes que viajan como solicitud hacia el servidor.

Concepto Clave: El encabezado filtra por IPs y puertos; 'flow' filtra por el estado y dirección de la sesión TCP.

Coincidencia de Patrones: content

`content:"texto";`

Busca una secuencia específica de caracteres o bytes dentro de los datos inspeccionados. No necesita coincidir con todo el contenido del paquete. Por defecto, distingue entre mayúsculas y minúsculas ("Login" no es igual a "LOGIN").

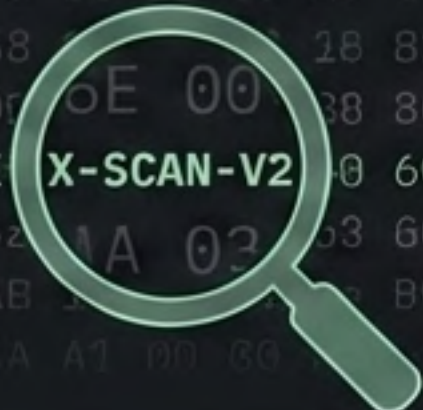


GET



El peligro de ser genérico

Una regla como `content:"GET";` generará una alerta por casi CADA petición web de tu red, ahogando al analista en ruido operativo.



X-SCAN-V2



Precisión

Regla de oro: El contenido debe ser tan específico como el evento que intentas detectar (ej. un marcador único o una firma de malware).

Identidad y Trazabilidad de la Regla



`msg:"Texto descriptivo";`

El mensaje que el analista leerá en pantalla cuando se dispare la alerta. Debe ser claro, útil y dar contexto.



`sid:1000050; (Snort ID)`

El número de cédula de la regla. Identificador único global. Importante: Las reglas locales personalizadas deben usar un SID a partir de 1000000.



`rev:2; (Revision)`

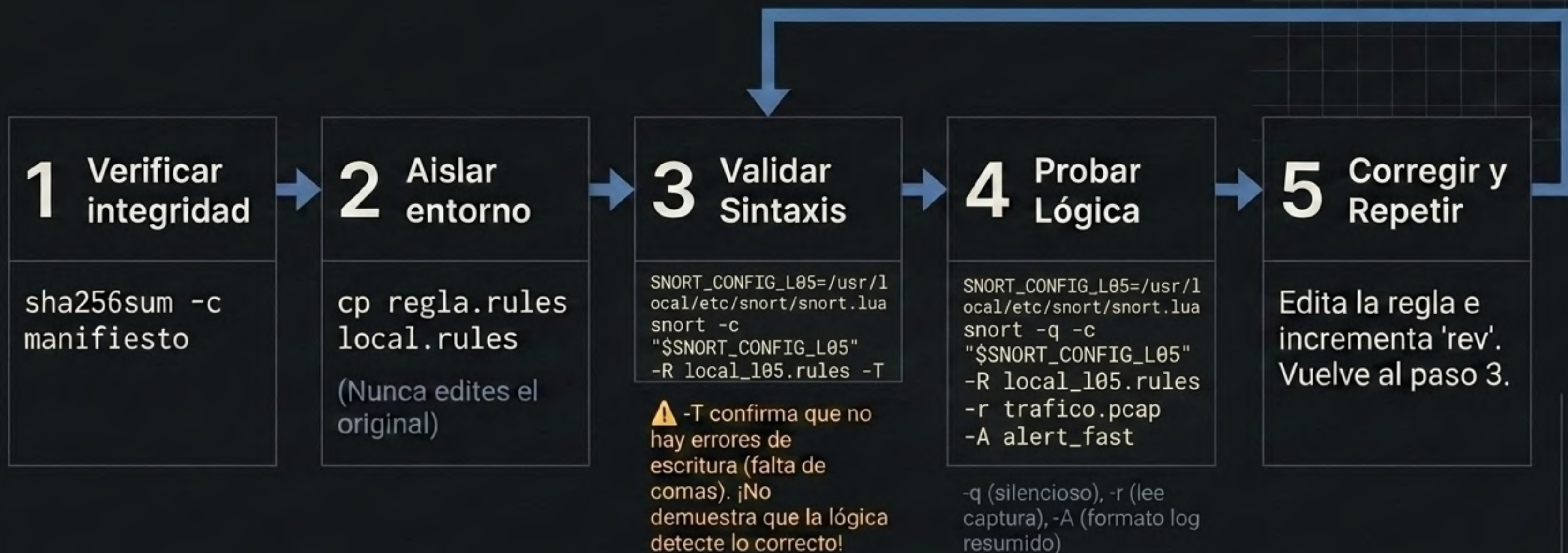
El control de versiones. Al modificar una regla, incrementa su número de revisión para mantener la trazabilidad. En este laboratorio se exige hacerlo.

La Matriz del Analista: Errores de Detección

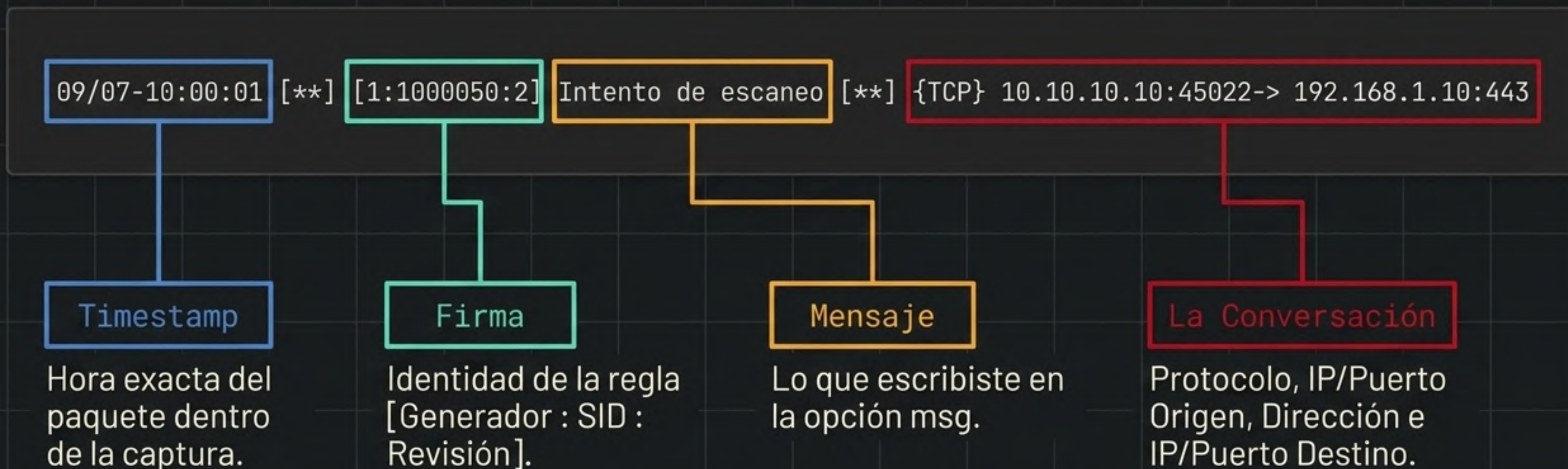
Afinar una regla significa minimizar dos errores operativos críticos.

		Tráfico Real	
		Legítimo	Malicioso
Acción del IDS	Alerta	Falso Positivo (Ruido) El IDS alerta cuando no debía. Ej.: Generar una alerta porque una consulta legítima contiene la palabra "SELECT", interpretándola como un posible ataque.	Verdadero Positivo Detección exitosa.
	Silencio	Verdadero Negativo Flujo normal permitido.	Falso Negativo (Peligro) El IDS NO alerta cuando sí debía. Ej: El atacante usó mayúsculas y la regla buscaba minúsculas; el ataque pasó invisible.

Ciclo de Afinamiento de Reglas



Descifrando el Log (alert_fast)



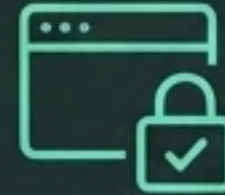
Tip del Analista: En un laboratorio, el puerto de origen (ej. 45022) es la clave visual para identificar exactamente qué caso de prueba generó la alerta.

Diseñando Casos de Prueba

Una regla solo es confiable si sobrevive a tráfico engañoso. No basta con probar el camino feliz.

Prueba de Contenido (Caso Positivo)

Tráfico con el texto malicioso exacto.



-> Debe generar alerta.

Prueba de Sensibilidad (Caso Negativo)

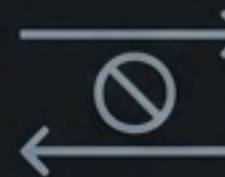
Tráfico con el texto mal escrito o usando otras mayúsculas/minúsculas.



-> No debe alertar.

Prueba de Dirección (Caso Negativo)

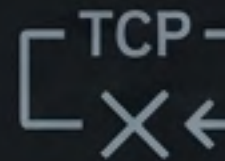
El texto exacto viaja, pero en reversa (desde el Servidor hacia el Cliente).



-> No debe alertar (si usamos ->).

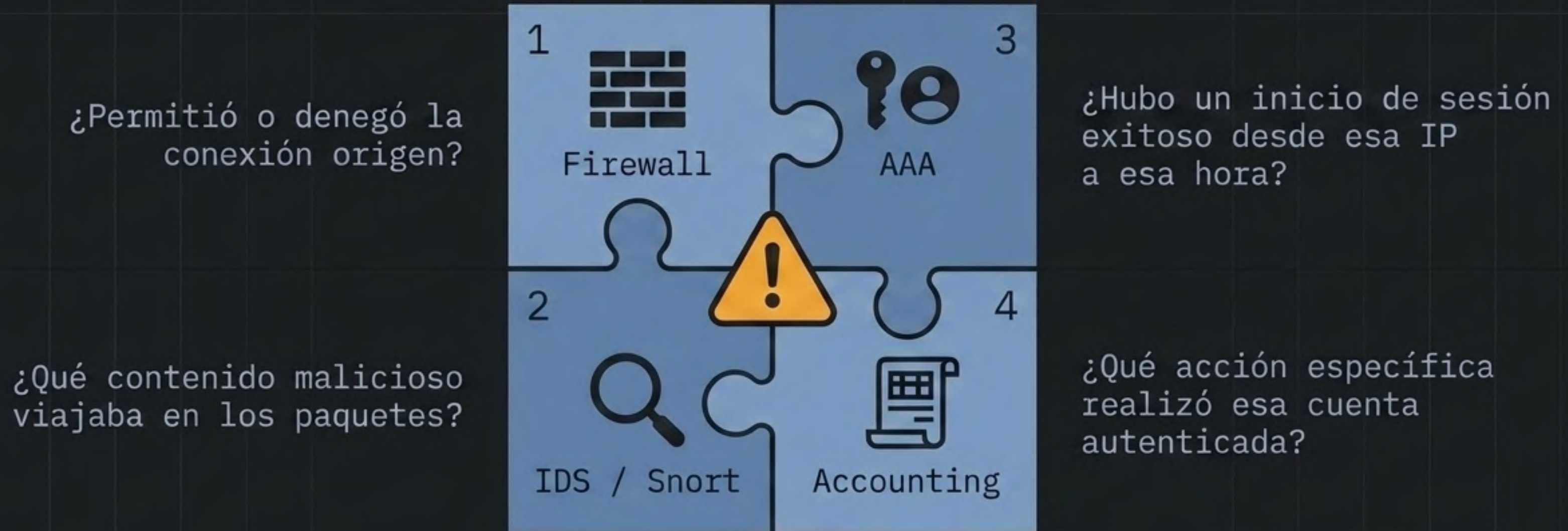
Prueba de Estado (Caso Negativo)

Tráfico que contiene la palabra pero no forma parte de una conexión TCP establecida (rechazado por 'flow').



-> No debe alertar.

El IDS no trabaja solo (Correlación de Eventos)



Regla de Oro de la Ciberseguridad: Una dirección IP no es una persona. Un evento de IDS solo indica "tráfico coincidente". La atribución del ataque a un individuo exige cruzar la alerta con evidencia adicional y suficiente proveniente de AAA, Accounting u otros registros. No asumas identidades.

Síntesis: Checklist de Resolución

Proceso Mental

- ☐ 1. Identificar el objetivo (Origen, Destino, Dirección).
- ☐ 2. Restringir el Encabezado (->, IPs, Puertos).
- ☐ 3. Ajustar el Cuerpo (flow, content).
- ☐ 4. Incrementar rev para mantener la trazabilidad de los cambios.
- ☐ 5. Validar sintaxis (-T) y probar casos en la captura (-r).
- ☐ 6. Correlacionar registros sin inventar atribuciones.

Herramientas de Apoyo (Opcionales)

```
cat archivo
```

Lee un archivo de texto o log.

```
tshark -r trafico.pcap -q -z conv,tcp
```

Lista las conversaciones de la captura.

```
diff -u original.rules local.rules
```

Compara y muestra tus modificaciones.

```
grep 'palabra' registros.csv
```

Filtra eventos relevantes.